Section 1 — Incident Header

Incident ID: INC-20260413-002
Date: 13 April 2026
Time Opened (IST): 20:42 IST
Severity: Critical
Client: MediCore Hospital Group
Industry: Healthcare
L1 Analyst: Priya Nair
L2 Analyst: Rohan Desai
L3 Analyst: Nisha Kapoor
Current Status: Under Investigation — Escalated to L2
Sentinel Incident Number: 45821

Section 2 — Client & Environment Context

MediCore Hospital Group is a multi-location healthcare provider operating across India, with its primary headquarters in Mumbai and five satellite hospitals in Pune, Nashik, Bengaluru, and Hyderabad. The organization employs approximately 2,300 staff, including medical professionals, administrative personnel, and third-party consultants. Its infrastructure is heavily digitized, with electronic health records (EHR), radiology imaging systems, and patient billing platforms all hosted within a hybrid cloud environment.

From a security standpoint, MediCore represents a high-value target. Patient health records contain sensitive personally identifiable information (PII), medical histories, insurance data, and payment details — all of which are highly monetizable on underground markets. Additionally, any disruption to hospital systems has immediate real-world consequences, increasing the likelihood of ransom compliance or rapid incident response pressure.

The organization operates on a hybrid identity model, with an on-premises Active Directory synchronized to Azure AD via Azure AD Connect. All users authenticate through Azure AD, with Conditional Access enforcing MFA for remote logins and privileged roles. The company holds Microsoft 365 E5 licensing, giving them full deployment of Defender for Endpoint, Defender for Office 365 Plan 2, Defender for Identity, and Microsoft Purview.

Endpoints include approximately 1,800 Windows 10/11 workstations and 120 Windows Server 2022 systems. Email remains a primary communication channel, with heavy reliance on Outlook and SharePoint for collaboration. Given the nature of healthcare operations, staff frequently receive attachments — lab reports, insurance forms, and external referrals — making email-based attacks particularly difficult to distinguish from legitimate traffic.

At the time of this incident, the hospital was in the middle of onboarding a new insurance partner, resulting in increased external email exchanges and document sharing — a detail that subtly lowered user suspicion toward incoming attachments.

Section 3 — Attack Narrative (Attacker Perspective)

The attacker had been watching MediCore for weeks before making a move.

Healthcare organizations were predictable. High email volume. Time-sensitive operations. Staff trained to act quickly, not cautiously. All it took was the right moment — and the right disguise.

The attacker began by registering a domain that closely resembled a known insurance partner recently announced in MediCore's public press release. The difference was almost invisible — a single swapped character in the domain name. The WHOIS registration was completed just seven days prior, using privacy shielding to obscure ownership.

Next came the payload.

The attacker crafted a phishing email impersonating the insurance partner's onboarding team. The tone was professional, slightly urgent — "updated claim processing template," "mandatory compliance format," "immediate review required." Attached was an Excel file named **"Insurance_Claim_Format_Update.xlsm."**

Inside that file was the real weapon.

The macro embedded within the spreadsheet was designed to execute only when the user enabled content. When triggered, it launched a hidden PowerShell command — obfuscated just enough to evade simple pattern detection. The command reached out to an external server controlled by the attacker, pulling down a credential harvesting page disguised as a Microsoft 365 login portal.

The attacker didn't need malware persistence at this stage. Credentials were the goal.

At 20:18 IST, the email was delivered successfully into a target user's inbox — a billing department employee with access to patient insurance records. At 20:20 IST, the attachment was opened. At 20:21 IST, macros were enabled.

The payload executed exactly as planned.

But instead of silently exfiltrating data, the attacker forced interaction — redirecting the user to a fake login page. It appeared legitimate. Same branding. Same layout. Even the URL looked convincing at a glance.

The user entered their credentials.

The attacker now had a valid username and password.

What followed was deliberate restraint.

Rather than logging in immediately — which could trigger suspicion — the attacker waited. For 22 minutes, no activity. No noise. Just patience.

At 20:43 IST, the attacker initiated a login attempt from a new device using the stolen credentials. The IP originated from an unfamiliar geographic location. MFA was prompted — and this was the only uncertainty in the plan.

But the attacker had anticipated fatigue.

The login prompt appeared to the user shortly after they had already interacted with the phishing document. In the confusion of the moment, the user approved the request, assuming it was part of the document access process.

That single approval was enough.

Within seconds, the attacker had full access to the user's Microsoft 365 account — mailbox, SharePoint access, and internal communication threads. From here, the attacker could pivot: search for sensitive documents, identify additional targets, or prepare for internal phishing using a trusted account.

The initial foothold was complete.

The real operation was just beginning.

Section 4 — Detection & Alert

At 22:14 IST, the quiet rhythm of the night shift was interrupted not by the usual Sentinel alert tone, but by a helpdesk escalation ticket that had already been converted into a Sentinel incident. The source was **Microsoft Defender for Office 365**, and the alert had been ingested into Sentinel via the connected data connector.

The Sentinel analytics rule that triggered the incident was:

Rule Name: *Malicious Attachment Delivered and Post-Delivery User Interaction Detected*
Severity: Critical

Rule Logic (KQL):

// Identify users who received a malicious attachment and subsequently logged in from a new IP/device

```
let MaliciousEmailRecipients = EmailAttachmentInfo
| where TimeGenerated > ago(2h)  // Scope to recent timeframe
| where ThreatTypes has "Malware"  // Attachment flagged as malicious
| project RecipientEmailAddress, AttachmentFileName, SHA256, TimeGenerated;


let SuspiciousSignins = SigninLogs
| where TimeGenerated > ago(2h)  // Same timeframe
| where ResultType == 0  // Successful login
| where Location !in ("IN")  // Outside expected geography (India baseline)
| project UserPrincipalName, IPAddress, AppDisplayName, TimeGenerated;


MaliciousEmailRecipients
| join kind=inner SuspiciousSignins
on $left.RecipientEmailAddress == $right.UserPrincipalName
| project RecipientEmailAddress, AttachmentFileName, SHA256, IPAddress, AppDisplayName,
TimeGenerated
```

What triggered the rule:

- Email delivered at **21:52 IST** to user: dr.anita.sharma@medicore.com
- Attachment: Patient_Report_Q4.xlsm
- SHA256 hash flagged as malicious by Defender for Office 365 detonation
- At **22:14 IST** (22 minutes later), a **successful Azure AD login**
    - IP Address: 185.193.88.47
    - Location: Bucharest, Romania
    - Application: Office 365 Exchange Online
    - Device: Unregistered / unknown

How the alert appeared in Sentinel:

- **Title:** *Malicious Attachment Interaction Followed by Suspicious Login*

- **Severity:** Critical
- **Entities:**
    - User: dr.anita.sharma@medicore.com
    - IP: 185.193.88.47
    - File Hash: 8f3c9e5c2d4a...
- **Timestamp:** 22:14 IST
- **Status:** New

The alert sat at the very top of Priya's queue — not because of volume, but because of severity. A user had interacted with a malicious attachment, and within minutes, a successful login occurred from a completely foreign geography.

The bridge between initial access and account compromise had already been crossed.

Section 5 — L1 Triage (Priya Nair)

Priya had been staring at a relatively calm Sentinel queue for the last fifteen minutes, her chair slightly reclined, one hand resting near her keyboard. The low hum of the SOC floor at night was familiar — fewer conversations, fewer alerts, just the occasional Teams notification blinking on her secondary monitor.

At 22:15 IST, the Sentinel incident list refreshed.

A **Critical** alert slid into the top position.

She didn't click it immediately.

Instead, she leaned forward and read the incident line first — a habit she had built over time.

"Malicious Attachment Interaction… Suspicious Login… same user."

Her eyes moved to the entity column.

dr.anita.sharma@medicore.com

A doctor. Not IT. Not admin. But still high-value — access to patient data.

She clicked the incident.

The right-hand panel expanded. She read the alert description slowly, lips barely moving as she traced the sequence: malicious Excel macro → user interaction → successful login from Romania.

“Romania?” she muttered under her breath.

Her fingers moved quickly — **Tab 3**. She opened **Microsoft Defender for Office 365**.

She searched for the recipient.

The email trace loaded.

Subject line: *“Updated Patient Lab Report — Urgent Review Required”*

Sender display name: *MediCore Diagnostics Team*

But the actual sender domain? medicore-support.co

Not the real domain.

She clicked into the attachment.

The detonation report was already there. Excel macro-enabled file. Behavior flagged: PowerShell execution, outbound HTTP request to external domain.

She didn’t need to see more.

She switched back to Sentinel.

Tab 2 — Entity Behavior

She opened the user timeline for dr.anita.sharma.

Last 24 hours of activity appeared.

Normal logins from Mumbai IP ranges. Hospital network. Consistent pattern.

Then at **22:14 IST** — a single clean break.

Successful login.

Romania.

New device.

She paused.

Her fingers hovered over the keyboard.

What if the user is traveling?
No. Not at 10 PM IST, 22 minutes after opening a malicious file. Too tight.

She opened **SigninLogs** view from the entity panel.

Filtered for the user.

One successful login. No prior failures. No MFA failure attempts.

She narrowed her eyes.

“Did MFA even trigger?”

She checked the authentication details.

MFA: **Satisfied**.

Her brow tightened.

Did the attacker proxy the session? Token theft? Or did the user unknowingly approve something?

She exhaled slowly.

This wasn’t just phishing. This was already account access.

She moved to **Tab 6 — Microsoft Teams (SOC-Incidents channel)**.

Before typing, she flipped back to Sentinel and wrote her incident comment:

“User received malicious macro-enabled attachment at 21:52 IST. Defender O365 detonation confirms PowerShell execution behavior. At 22:14 IST, successful login observed from IP 185.193.88.47 (Romania), new device. No prior login pattern from this geography. MFA marked as satisfied — unclear if user interaction or session hijack. Strong indication of credential compromise.”

She checked the clock.

22:18 IST.

Within SLA.

She began typing the escalation.

Escalation Message (SOC-Incidents — 22:19 IST):

@Rohan Desai — Critical Escalation

User: dr.anita.sharma@medicore.com

- Malicious Excel macro attachment delivered at 21:52 IST (Defender O365 confirmed malware)
- User interaction confirmed (detonation shows PowerShell execution)
- At 22:14 IST, successful login from Romania IP 185.193.88.47
- New device, no prior geo history
- MFA shows “satisfied” — unclear if user-approved or token/session replay

Initial Assessment: Likely credential compromise post-phishing

Need L2 to validate login path, session details, and post-auth activity. Potential active account takeover.

She hit Enter.

Then she leaned back — but didn’t take her eyes off the screen.

Section 6 — L2 Investigation (Rohan Desai)

Rohan was at home when the Teams notification appeared.

He didn’t open Sentinel immediately.

Instead, he read Priya’s message twice.

Malicious macro. 22-minute gap. Foreign login. MFA satisfied.

He nodded slightly.

“Classic.”

He opened his laptop and connected into the SOC Sentinel workspace.

22:23 IST.

The incident loaded on his primary screen.

He expanded the alert list. There was only one correlated alert — but it was rich.

He opened the **Investigation Graph**.

User → Email → Attachment → Login IP.

A clean chain.

But clean didn't mean complete.

He opened **Notepad++** on his second monitor.

Typed his first question:

// Q1: Was the login truly anomalous, and what were the authentication details?

Then he moved to Sentinel's Log Analytics window.

Query 1 — Authentication Analysis

```
SigninLogs
| where TimeGenerated > ago(2h)  // Focus on incident timeframe
| where UserPrincipalName == "dr.anita.sharma@medicore.com"  // Target user
| project TimeGenerated, IPAddress, Location, DeviceDetail, AppDisplayName, ResultType,
AuthenticationRequirement, MFAResult
| order by TimeGenerated desc
```

Result:

- 22:14 IST — Success
- IP: 185.193.88.47
- Location: Romania
- Device: Unknown (no device ID, browser-based login)
- MFA: **Satisfied**
- Authentication Requirement: Single factor (token-based session)

Rohan leaned back slightly.

"Token replay," he said quietly.

No failed attempts. No brute force. Clean login.

That meant the attacker didn't guess credentials — they *captured* them.

Or intercepted session tokens.

He typed his next question.

// Q2: What activity occurred after the suspicious login?

Query 2 — Post-Login Activity

```
OfficeActivity
| where TimeGenerated > datetime(2026-04-13 22:14:00)  // After suspicious login
| where UserId == "dr.anita.sharma@medicore.com"
| project TimeGenerated, Operation, Workload, ClientIP, UserAgent
| order by TimeGenerated asc
```

Result:

- 22:15 IST — MailboxLogin
- 22:16 IST — InboxRuleCreated
- 22:17 IST — MailItemsAccessed (multiple entries)
- 22:18 IST — SendOnBehalf attempt (blocked)

Rohan's eyes narrowed.

"Inbox rule. There it is."

He clicked into the InboxRuleCreated event.

Rule name: *"Forward_All"*
Forwarding address: anita.sharma.secure@protonmail.com

He exhaled slowly.

The attacker wasn't just testing access.

They were establishing persistence and exfiltration.

He typed another note.

// Q3: Confirm phishing delivery and attachment details

Query 3 — Email Evidence

```
EmailEvents
| where TimeGenerated > ago(3h)
| where RecipientEmailAddress == "dr.anita.sharma@medicore.com"
| project TimeGenerated, SenderFromAddress, Subject, NetworkMessageId
```

Followed by:

```
EmailAttachmentInfo
| where TimeGenerated > ago(3h)
| where RecipientEmailAddress == "dr.anita.sharma@medicore.com"
```

| project FileName, SHA256, ThreatTypes

Result:

- Sender domain spoofed
- Attachment flagged as malware
- Hash confirmed malicious in VirusTotal (multiple detections)

Rohan opened **VirusTotal**.

Hash: 38/72 engines flagged.

He checked **AbuseIPDB** for the login IP.

Score: 92 — known malicious activity.

Then **WHOIS**.

Domain age: 6 days.

He nodded.

Everything aligned.

Attack Timeline

Timestamp (IST)	Event	Data Source	MITRE Technique
21:52	Phishing email delivered with macro attachment	EmailEvents	T1566.001
21:54	User opens attachment, macro executes	EmailAttachmentInfo	T1059.001
22:14	Successful login from Romania IP	SigninLogs	T1078
22:16	Inbox forwarding rule created	OfficeActivity	T1114.003
22:17	Mailbox data accessed	OfficeActivity	T1114

IOC Table

IOC	Type	Source	Enrichment Result
185.193.88.47	IP	SigninLogs	AbuseIPDB score 92 (malicious)
medicore-support.co	Domain	EmailEvents	WHOIS: 6 days old
8f3c9e5c2d4a...	File Hash	EmailAttachmentInfo	VirusTotal: 38 detections
anita.sharma.secure@protonmail.com	Email	OfficeActivity	External exfiltration address

---

MITRE ATT&CK Mapping

- T1566.001 — Spearphishing Attachment
- T1059.001 — PowerShell Execution
- T1078 — Valid Accounts
- T1114.003 — Email Forwarding Rule
- T1114 — Email Collection

Containment Recommendations

1. Immediately **disable user account** in Azure AD and revoke all active sessions
2. Reset credentials and enforce **MFA re-registration**
3. Remove malicious **Inbox forwarding rule** via Exchange Online
4. Block IP 185.193.88.47 in Conditional Access named locations
5. Add domain medicore-support.co to **tenant block list**
6. Run full endpoint scan via Defender for Endpoint on user device
7. Review all mailbox access logs for potential data exposure
8. Notify compliance team due to potential patient data exposure (HIPAA context)

Rohan leaned back, looking at the timeline.

Delivery. Execution. Access. Persistence.

Clean. Efficient.

He opened the incident and began documenting everything.

Then he tagged Priya in the comments:

“Confirmed credential compromise via phishing. Inbox rule established. Containment required immediately.”

The case was no longer a suspicion.

It was a confirmed breach in progress.

Section 7 — L3 Detection Tuning (Nisha Kapoor)

At 09:10 IST the next morning, Nisha sat down at her workstation, a fresh cup of coffee placed just to the right of her keyboard. Rohan’s investigation report was already open on her ultra-wide monitor, the timeline and IOC tables stretching across the screen.

She didn’t skim.

She read it line by line.

Phishing email. Macro execution. Credential capture. Twenty-two minutes of silence. Then login. Then inbox rule.

Her eyes paused on one detail.

“Detection fired only after successful login.”

She leaned back slightly.

“That’s late,” she said quietly.

The attacker had already gained access by the time Sentinel raised the alarm. The detection worked — but not early enough to prevent impact.

She opened the **Microsoft Sentinel Analytics Rules editor** and pulled up the rule:

Malicious Attachment Delivered and Post-Delivery User Interaction Detected

The current logic appeared on screen.

Before-State KQL Rule

```
let MaliciousEmailRecipients = EmailAttachmentInfo
| where TimeGenerated > ago(2h)
| where ThreatTypes has "Malware"
| project RecipientEmailAddress, AttachmentFileName, SHA256, TimeGenerated;


let SuspiciousSignins = SigninLogs
| where TimeGenerated > ago(2h)
| where ResultType == 0
| where Location !in ("IN")
| project UserPrincipalName, IPAddress, AppDisplayName, TimeGenerated;


MaliciousEmailRecipients
| join kind=inner SuspiciousSignins
on $left.RecipientEmailAddress == $right.UserPrincipalName
```

She tapped her pen lightly on the desk.

The issue was clear.

Identified Weakness (one sentence):
The rule only triggers after a successful login occurs, missing the critical window between malicious attachment execution and account compromise.

She opened Notepad++ and began writing.

“If we can’t stop the login,” she murmured, “we can at least catch the setup earlier.”

She rewrote the logic to introduce **pre-compromise detection signals** — specifically, user interaction with malicious attachments combined with suspicious macro execution behavior, even before authentication events.

After-State Improved KQL Rule

```
// Detect users who interacted with malicious attachments AND showed macro execution behavior,

// regardless of whether a login has occurred yet


let MaliciousAttachmentInteraction = EmailAttachmentInfo
| where TimeGenerated > ago(2h)  // Recent emails
```

```
| where ThreatTypes has "Malware"  // Confirmed malicious attachment
| project RecipientEmailAddress, FileName, SHA256, TimeGenerated;


let SuspiciousProcessExecution = DeviceProcessEvents
| where TimeGenerated > ago(2h)  // Same timeframe
| where ProcessCommandLine has_any ("powershell", "EncodedCommand", "IEX")  // Macro-spawned PowerShell indicators
| project DeviceName, InitiatingProcessAccountName, ProcessCommandLine, TimeGenerated;


MaliciousAttachmentInteraction
| join kind=inner SuspiciousProcessExecution
on $left.RecipientEmailAddress == $right.InitiatingProcessAccountName
| project RecipientEmailAddress, FileName, ProcessCommandLine, TimeGenerated
```

She reviewed it once more.

Now the rule didn’t wait for damage.

It flagged the moment a malicious attachment led to suspicious execution behavior — the exact pivot point where prevention was still possible.

She added a comment to the rule:

“This rule detects pre-authentication compromise signals by correlating malicious attachment interaction with macro-driven PowerShell execution. Designed to reduce time-to-detection before credential misuse.”

She leaned back.

“This would have fired at 21:54,” she said, glancing at the timeline.

Twenty minutes earlier.

Enough time to isolate the endpoint. Enough time to warn the user. Enough time to stop the login entirely.

She saved the draft and prepared it for deployment review.

For Nisha, detection wasn’t about catching attacks.

It was about catching them sooner.

Section 8 — Final Incident Report

Part A — Executive Summary

On April 13, 2026, MediCore Hospital Group experienced a targeted phishing attack in which a malicious email attachment led to unauthorized access to an employee's account. The attacker successfully obtained login credentials and accessed the user's mailbox from a foreign location.

The incident was detected within minutes of the suspicious login. Immediate action was taken to disable the account, remove unauthorized access rules, and block malicious infrastructure. No evidence of large-scale data exfiltration was confirmed, though mailbox access did occur.

Security controls functioned as designed, but improvements have been identified to detect similar threats earlier in the attack chain.

Part B — Full Technical Summary

Incident Type:
Phishing → Credential Theft → Account Takeover

MITRE ATT&CK Techniques:

- T1566.001 — Spearphishing Attachment
- T1059.001 — PowerShell Execution
- T1078 — Valid Accounts
- T1114.003 — Email Forwarding Rule
- T1114 — Email Collection

Timeline Summary:

Time (IST)	Event
21:52	Malicious email delivered with macro attachment
21:54	User opens attachment; macro executes PowerShell
22:14	Successful login from Romania IP

22:16	Inbox forwarding rule created
22:17	Mailbox access activity begins

Impact Assessment:

- One user account compromised
- Unauthorized mailbox access confirmed
- Inbox forwarding rule created (exfiltration risk)
- No confirmed bulk data exfiltration
- No lateral movement observed

IOC List:

IOC	Type	Enrichment
185.193.88.47	IP	AbuseIPDB score 92 (malicious activity)
medicore-support.co	Domain	Newly registered (6 days old)
8f3c9e5c2d4a...	File Hash	VirusTotal: multiple detections
anita.sharma.secure@protonmail.com	Email	External forwarding address

---

Containment Actions Taken:

- User account disabled and sessions revoked
- Password reset and MFA re-enrollment enforced
- Malicious inbox rule removed
- Malicious IP blocked via Conditional Access
- Domain added to tenant block list
- Endpoint scanned via Defender for Endpoint

Lessons Learned:

- Detection occurred post-compromise; earlier indicators were available
- Users remain susceptible to well-crafted phishing with macro attachments
- MFA alone does not prevent compromise when users approve requests
- Email-based attacks remain a primary entry vector in healthcare environments

---

Action Items:

Action	Owner	Priority	Target Date
Deploy improved pre-auth detection rule (macro + process correlation)	Nisha Kapoor (L3)	High	16 April 2026
Conduct targeted phishing awareness training for billing & medical staff	MediCore Security Team	High	25 April 2026
Enforce stricter Conditional Access (block high-risk geographies by default)	Azure Admin Team	High	18 April 2026
Enable automatic inbox rule anomaly alerts in Defender for O365	SOC Engineering	Medium	20 April 2026
Review all external email domain impersonation protections	Email Security Team	Medium	22 April 2026

Final Status: Resolved — Monitoring for follow-on activity